

Mẫu mô tả Pull Request

Mẫu số 03 — dán vào ô mô tả mỗi khi mở PR.

Bản này đã được cài sẵn thành template GitHub tại [.github/pull_request_template.md](#), nên khi mở PR nó tự hiện ra. File này giữ lại để tra cứu và để giải thích cách điền.

Mục tiêu: người review hiểu PR trong **2 phút** mà không cần hỏi bạn.

Nội dung mẫu

```
## Mã nhóm tính năng
<!-- Ví dụ: H02 · Đăng nhập & quản lý phiên -->

## PR này làm gì
<!-- 1-3 câu. Viết cho người KHÔNG làm phần này.
      Tốt:   "Thêm luồng đăng nhập cấp JWT 15 phút + refresh token 7 ngày có xoay vòng."
      Không: "Update auth", "Fix theo comment", "Làm tiếp phần hôm qua". -->

## Vì sao làm theo cách này
<!-- Chỉ điền khi có lựa chọn không hiển nhiên. Đây là chỗ tiết kiệm thời gian
      review nhiều nhất: nói trước lý do thì người review không phải đoán rồi hỏi lại. -->

## Loại thay đổi
- [ ] `feat` - thêm tính năng
- [ ] `fix` - sửa lỗi
- [ ] `refactor` - sửa cấu trúc, không đổi hành vi
- [ ] `test` - chỉ thêm test
- [ ] `docs` - chỉ sửa tài liệu
- [ ] `chore` - cấu hình, CI, phụ thuộc

## Cách kiểm chứng
<!-- Lệnh copy-dán chạy được ngay, hoặc các bước bấm trên giao diện.
      Người review PHẢI chạy được, không chỉ đọc code. -->

``bash
```

Ảnh hưởng tới người khác

- ☐ Không ảnh hưởng ai
- ☐ Có — điền bảng dưới

Ảnh hưởng gì	Ai	Họ cần làm gì

Checklist trước khi xin review

- ☐ CI xanh
- ☐ Có test cho đường đúng **và** ít nhất một đường sai
- ☐ Không commit khoá / mật khẩu / token
- ☐ Không log mật khẩu, OTP, số thẻ, số tài khoản đầy đủ, SĐT đầy đủ
- ☐ Đã cập nhật `contracts/openapi/` nếu đổi hợp đồng API
- ☐ Đã cập nhật `.env.example` nếu thêm biến môi trường
- ☐ Migration chạy được từ database rỗng
- ☐ File mới có khối comment đầu file nói rõ trách nhiệm

Báo cáo tính năng

Ảnh chụp màn hình

Hai ví dụ để so sánh

Ví dụ đạt

```markdown

## Mã nhóm tính năng

K02 · SSRF guard & tăng fetch an toàn

## PR này làm gì

Chặn mọi request fetch tới IP nội bộ. Phân giải DNS trước, kiểm tra IP đích rồi mới mở kết nối, và kiểm tra lại ở từng bước chuyển hướng.

## Vì sao làm theo cách này

Kiểm tra IP sau khi kết nối là vô nghĩa: kẻ tấn công dùng DNS rebinding đổi bản ghi giữa lúc kiểm tra và lúc kết nối. Nên phải resolve trước, giữ IP đã kiểm tra, rồi kết nối thẳng tới IP đó.

Kiểm tra lại ở mỗi redirect vì URL đầu tiên có thể là domain công khai hoàn toàn bình thường, redirect mới trở về 127.0.0.1.

## Cách kiểm chứng

```bash

cd services/worker && mvn test -Dtest=SsrfGuardTest

curl -X POST localhost:8080/v1/scan/url -d '{"url":"http://169.254.169.254"}'

kỳ vọng: 400 BLOCKED_INTERNAL_ADDRESS

Ảnh hưởng tới người khác

| Ảnh hưởng gì | Ai | Họ cần làm gì |
|--|-------------|--|
| QR chứa URL phải đi qua <code>SafeFetchClient</code> | Thắng (T03) | Gọi <code>safeFetchClient.fetch()</code> thay vì <code>RestTemplate</code> trực tiếp |

```
### Ví dụ không đạt

```markdown
PR này làm gì
Fix SSRF

Cách kiểm chứng
Test rồi ok
```

Người review không biết fix cái gì, sửa ở đâu, chạy thử thế nào, và có làm hỏng phần của mình không. PR kiểu này sẽ bị trả về và tốn thêm một vòng trao đổi — chậm hơn hẳn so với việc bỏ 3 phút viết mô tả tử tế.

Mẫu: Mô tả PR v1.0 · Cài sẵn tại `.github/pull_request_template.md`